CYPHER GROUP INC. · SIMULATED CASE STUDY

CGI-GAP-001 — NIST CSF 2.0 Security Gap Assessment & Maturity Scorecard

Cypher Group Inc. · Version 1.0 · 15 September 2026

> **Case study notice.** Cypher Group Inc. is a simulated company. Every organisation, person, system, finding, score and figure in this document was created to demonstrate applied GRC methodology. No real company data, customer data or security finding is present. This document is a portfolio artifact and must not be presented as evidence of employment or of a real engagement.

Field	Value
Document ID	CGI-GAP-001
Title	NIST CSF 2.0 Security Gap Assessment and Maturity Scorecard
Version	1.0
Status	Final — issued for management review
Assessment date	15 September 2026
Prepared by (Assessor)	O.S
Approving authority	Jerry Gold, Chief Executive Officer
Framework	NIST Cybersecurity Framework (CSF) 2.0 — NIST CSWP 29, published 26 February 2024
Assessment depth	Category level — all 22 Categories across all 6 Functions
Maturity scale	0–4 CMMI-style capability maturity (defined in §3)
Secondary mapping	ISO/IEC 27001:2022 Annex A
Inputs consumed	CGI-POL-001 to CGI-POL-005 v1.0 · CGI-TRK-001 · EXC-001 to EXC-003 · CGI-RSK-001 v1.0
Next review	15 March 2027, or on material change

Headline result: overall current maturity 1.23 / 4.00 against a declared target of 2.68 / 4.00 — an average gap of 1.45 across 22 Categories.

Contents

1. Purpose, scope and how to read this document
2. Methodology and evidence standard
3. Maturity scale and declared target state
4. Scorecard summary — all 22 Categories
5. Detailed assessment — 22 Category findings
6. Function-level heatmap and radar chart
7. Prioritised remediation roadmap
8. Executive summary (one page)
9. Internal consistency checks and limitations
10. Glossary

---

1. Purpose, scope and how to read this document

1.1 Purpose

Cypher Group Inc. has, over the preceding two work packages, written an information security policy pack (CGI-POL-001 to CGI-POL-005) and built a risk register (CGI-RSK-001). Neither of those answers the question leadership actually needs answered: **what are we still missing entirely, how far are we from where we have decided we need to be, and in what order should we close the distance?**

This assessment answers that question by measuring Cypher Group Inc.'s current cybersecurity capability against all 22 Categories of the NIST Cybersecurity Framework 2.0, scoring each on a 0–4 capability maturity scale, comparing each score against a declared and justified target state, and converting the resulting gaps into an owned, sequenced and costed remediation roadmap.

1.2 What a framework is, and why this one

A **framework** is a published, agreed list of the outcomes a well-run security programme is expected to achieve, arranged so an organisation can check itself against it one item at a time. It is not a law, not a product and not a set of instructions — it states *what* outcome to achieve and leaves *how* to the organisation.

NIST CSF 2.0 was selected for three reasons specific to Cypher Group Inc.:

- **It is free, public and non-certifiable**, so it can be adopted immediately without audit cost at a stage where the company has no certification budget.
- **Version 2.0 (February 2024) is explicitly scoped to organisations of any size**, unlike version 1.1, which was aimed at critical infrastructure. A 50-person SaaS company is squarely inside its intended audience.
- **It maps cleanly onto ISO/IEC 27001:2022**, which is Cypher Group Inc.'s stated 18-month destination. Every Category in this assessment carries an Annex A mapping, so this document is also the first draft of the evidence base for a future Statement of Applicability.

1.3 How the framework nests

```
CSF CORE
 └── FUNCTION        (6)    GOVERN · IDENTIFY · PROTECT · DETECT · RESPOND · RECOVER
      └── CATEGORY   (22)   outcome groups inside a Function      <-- THIS ASSESSMENT
           └── SUBCATEGORY (106)  single specific outcomes
                └── Implementation Examples & Informative References (non-binding)
```

Functions hold Categories. Categories hold Subcategories. A reference such as `PR.AA-05` reads as Function PROTECT → Category *Identity Management, Authentication and Access Control* → Subcategory 5.

GOVERN is new in CSF 2.0 and is drawn as a ring around the other five Functions rather than as a sixth slice, because NIST concluded that the most common point of failure in real programmes is not technology but accountability, policy and oversight. That conclusion is borne out here: Cypher Group Inc.'s single strongest Category and two of its weakest all sit in areas GOVERN determines.

1.4 Scope

In scope	Out of scope
All 22 CSF 2.0 Categories, assessed at Category level	Subcategory-level assessment of all 106 outcomes (planned as a future revision)

In scope	Out of scope
The CloudCo production environment, CodeCo, ChatCo, OfficeCo and PaymentsCo	Physical security of the office (no data centre is operated)
All 50 employees and the CGI-POL-001 §4.4 BYOD estate	Penetration testing or technical validation of any control
The CGI-POL-001 to CGI-POL-005 policy pack and CGI-TRK-001 evidence	Assessment of the five third-party providers themselves (scoped as Project 4)
CGI-RSK-001 v1.0 risks R-001 to R-005 and control gaps CG-01 to CG-05	Financial audit, privacy impact assessment or GDPR Article 30 records

1.5 How to read a finding

Every Category in §5 carries the same sixteen fields. Two of them do the real work:

- **Current State Observation** states what is true today, citing a specific policy clause and the specific evidence that does or does not show it operating. A finding that cannot cite a clause and an evidence source is an opinion, and has been excluded.
- **Risk if Unaddressed** states the business consequence, not the technical one, and where possible ties back to a named risk in CGI-RSK-001 so that this assessment and the register agree with one another.

---

2. Methodology and evidence standard

2.1 Method

1. **Framework selection and scoping.** NIST CSF 2.0 at Category level; 22 Categories; ISO/IEC 27001:2022 Annex A carried as a secondary mapping.
2. **Target state declaration.** The target state was declared and justified **before** any score was assigned (§3.2). Scoring against an undeclared target produces an unfalsifiable assessment.
3. **Evidence review.** CGI-POL-001 to CGI-POL-005 v1.0, the CGI-TRK-001 sign-off and training tracker, the Exception Register EXC-001 to EXC-003, and CGI-RSK-001 v1.0 including risks R-001 to R-005, control gaps CG-01 to CG-05 and treatment actions TP-01 to TP-10.
4. **Current-state scoring.** Each Category scored 0–4 against the written scale in §3.1, with the score justified in prose against cited evidence.
5. **Gap calculation.** Gap = Target − Current, per Category and rolled up per Function.
6. **Risk linkage.** Every Category linked to the CGI-RSK-001 risk or control gap it bears on, and the scores reconciled against the register's residual positions (§9.1).
7. **Prioritisation.** Recommendations ranked by **risk reduction ÷ effort**, then re-sequenced where a dependency requires it, with every override stated explicitly.
8. **Verification.** All averages, rollups and ratios computed programmatically, not by eye.

2.2 The evidence standard applied

The distinction that governs every score in this document is the audit distinction between **design effectiveness** and **operating effectiveness**:

- **Design effectiveness** — the control is written properly and would work if it were followed. This is worth a maturity **2**.
- **Operating effectiveness** — the control demonstrably ran, on schedule, and produced a retained artifact proving it ran. This is what earns a **3**.

An approved, published policy that nobody has evidenced executing scores a 2, not a 3. This single rule is why an organisation that has just completed a five-policy programme scores 1.23 out of 4.00 rather than 3. It is not a criticism of the policy pack; it is the correct reading of what a policy pack is worth on its own.

2.3 Limitations

- This is a **documentation and evidence review**, not a technical assessment. No configuration was inspected, no scan was run and no control was tested. Where the assessment says a control is absent, it means no evidence of it was produced; a control could exist informally and be unrecorded — which would itself cap the score at 1.
- Scores are the assessor's judgement against a written scale, and a second assessor could reasonably differ by one level on individual Categories. The scale definitions in §3.1 exist to keep that variance bounded.
- CGI-RSK-001 contains five risk scenarios. Categories with no corresponding scenario in the register (notably **GV.SC**) are assessed on their own merits and flagged as outside register coverage.
- CGI-TRK-001 shows five illustrative personnel rows. Its rates (60% policy acknowledgement, 80% MFA, 60% induction training) are treated as representative of all 50 employees, which is where "roughly 20 staff" and "roughly ten accounts" come from.

---

3. Maturity scale and declared target state

3.1 The 0–4 capability maturity scale

NIST CSF 2.0 deliberately contains **no maturity model**. Its Tiers (1 Partial → 4 Adaptive) describe the rigour of an organisation's risk *governance*, not the maturity of individual controls, and NIST is explicit that Tiers are not maturity levels. A scale must therefore be supplied by the assessor and stated in writing. This assessment uses a CMMI-style 0–4 scale — **CMMI** being Capability Maturity Model Integration, developed at Carnegie Mellon University's Software Engineering Institute.

The scale measures **how repeatably and verifiably an outcome is achieved**, not whether anyone has heard of it.

Score	Level	Definition	Evidence required to claim this level
0	**Not Performed**	The outcome is not achieved in any form. No policy, no practice, no owner, no evidence. If asked, the honest answer is 'we do not do this'.	None. The absence is the finding.
1	**Initial / Ad Hoc**	The outcome is achieved occasionally, reactively and person-dependently. There is no written expectation, nothing is scheduled, and if the individual concerned left, the activity would stop. No reliable evidence is produced.	Anecdote only. Someone can describe having done it once.
2	**Documented / Repeatable**	An approved policy, standard or procedure exists, ownership is assigned and the expectation is communicated. Execution is inconsistent, incomplete or unevidenced. This is design effectiveness without operating effectiveness - the control would work if followed, but no artifact proves it was.	An approved, published document naming an owner. No execution record required.
3	**Defined and Operating**	The activity is performed consistently on a defined schedule by the assigned owner, and each occurrence produces retained evidence. Exceptions are recorded and tracked. This is design plus operating effectiveness and is the level at which an external auditor can test the control.	A dated, retained artifact per occurrence — a signed review record, a test result, a ticket, an exported log.
4	**Managed and Measured**	Performance of the activity is measured against defined metrics or KRIs with thresholds, the results are reported to leadership, and the activity is adjusted on the basis of the data rather than on opinion. Continuous improvement is evidenced.	A metric or KRI with a threshold, a reporting record to leadership, and a documented change made in response to the data.

Half-scores are not used. Where a Category sits between two levels it is scored down, because the lower score is the one the evidence supports.

Fragments do not lift a Category. A single clause somewhere in the policy pack that touches one outcome of a Category is recorded in the finding, but it does not move the Category up a level on its own. Three examples in this assessment: the CTO-approval rule for new services in CGI-POL-001 §4.6.1 (GV.SC), the 14-day endpoint patching rule in CGI-POL-

001 §4.4.3 (PR.PS), and the general Communications Lead role in CGI-POL-005 §4 (RC.CO). A Category is scored on whether its **core outcome** is written, owned and evidenced — **a clause is not a capability.** This is also why CGI-POL-001 §8 can map §4.4 to the Subcategory PR.PS-01 while PR.PS scores 0 at Category level: both statements are true. Each fragment is named in its finding so a reader can see it was weighed, not missed.

3.2 The declared target state

> **DECLARED TARGET STATE — Cypher Group Inc., to be achieved by Q4 2027**
>
> Cypher Group Inc. will operate at **NIST CSF Implementation Tier 2 (Risk Informed)** organisation-wide, expressed at Category level as:

- **Maturity 3 — Defined and Operating — in 15 Categories** that either (a) carry a CGI-RSK-001 risk that remains Medium or High after treatment, (b) are load-bearing for a GDPR obligation already committed to in writing, or (c) are routinely tested by enterprise customer security questionnaires.
- **Maturity 2 — Documented and Repeatable — in the remaining 7 Categories**, where a written, owned expectation is proportionate to the risk and no evidence of repeated execution is yet warranted.
- **Maturity 4 in no Category in this cycle.**

> Overall target: **2.68 / 4.00**.

Why this target, and not 4 across the board

Because maturity costs money and management attention, and level 4 buys measurement rather than protection. Recommending a uniform 4 would be professionally indefensible for this organisation, for four reasons:

1. **Proportionality.** Cypher Group Inc. has 50 employees, approximately USD 3.6M ARR (CGI-RSK-001 assumption A-01) and roughly 200 SMB customers. Level 4 requires metrics, thresholds, leadership reporting and data-driven adjustment for every Category; the standing management overhead alone would exceed the entire year-one security budget of USD 32,100 estimated in CGI-RSK-001.
2. **Sequencing.** Two Categories currently score **0** (PR.PS and PR.IR) and they are precisely where the two risks that stayed High after treatment (**R-004** and **R-005**) live. Spending on level-4 measurement in a Category that already works, while PR.PS sits at zero, is paying to measure your strengths while the hole stays open.
3. **Falsifiability.** A target of 4 everywhere is equivalent to having no target: every Category fails, no priority emerges, and the assessment produces 22 undifferentiated complaints rather than a fundable plan.
4. **Risk appetite.** Cypher Group Inc. faces no sector regulator beyond GDPR, holds no cardholder data (CGI-POL-004 §4.1.4, formalised as AVD-001) and sells to SMBs rather than to regulated enterprises. A Tier 2 / maturity-3 posture in the risk-bearing Categories is the level at which residual risk comes inside a reasonable appetite. Beyond that, further spend buys assurance the business is not being asked for.

Where the targets came from, Category by Category

Target	Applied to	Justification trigger
3	GV.RM, GV.RR, GV.PO, GV.OV, ID.AM, ID.RA, PR.AA, PR.AT, PR.DS, PR.PS, PR.IR, DE.CM, RS.MA, RS.CO, RC.RP	Carries a residual Medium or High risk from CGI-RSK-001, or a written GDPR commitment (CGI-POL-005 §5.6.3), or is a standard enterprise questionnaire item
2	GV.OC, GV.SC, ID.IM, DE.AE, RS.AN, RS.MI, RC.CO	Proportionate written expectation is sufficient at current risk and scale; will be re-targeted upward in the next cycle
4	—	Deliberately none. Revisit once the overall score exceeds 2.5 and an ISO 27001 certification decision is taken

GV.SC is the one target that will look too low to an experienced reader, and deliberately so. Supply chain is the company's largest unassessed exposure, but it currently scores **0**; a target of 3 in one cycle would require a full vendor assurance programme that does not yet have an owner or a budget. A target of 2 — a tiered vendor inventory with assurance artifacts on file — is what can actually be delivered, and the Category is explicitly flagged in §7 for re-targeting to 3 in the following cycle.

4. Scorecard summary — all 22 Categories

Full 16-column grid, one value per cell and ready to paste into Sheets or Excel: **`data/03-nist-csf-gap-assessment.csv`**. The summary below is the readable view; §5 carries every column in full for each Category.

Ref ID	Function	Category	Current	Target	Gap	Related Risk ID	Priority	Effort	Owner
GAP-001	GOVERN	GV.OC Organizational Context	**1**	2	**1**	R-005	P2	S	Chief Executive Officer
GAP-002	GOVERN	GV.RM Risk Management Strategy	**2**	3	**1**	R-004, R-005	P1	S	Chief Executive Officer
GAP-003	GOVERN	GV.RR Roles, Responsibilities and Authorities	**2**	3	**1**	R-003	P2	S	Chief Executive Officer
GAP-004	GOVERN	GV.PO Policy	**2**	3	**1**	R-001, R-002	P1	S	Chief Technology Officer
GAP-005	GOVERN	GV.OV Oversight	**1**	3	**2**	R-004, R-005	P2	S	Chief Executive Officer
GAP-006	GOVERN	GV.SC Cybersecurity Supply Chain Risk Management	**0**	2	**2**	R-005	P1	M	Chief Technology Officer
GAP-007	IDENTIFY	ID.AM Asset Management	**1**	3	**2**	R-003, R-005	P1	M	IT Operations Manager
GAP-008	IDENTIFY	ID.RA Risk Assessment	**3**	3	**0**	R-001, R-002, R-003, R-004, R-005	P2	S	Chief Technology Officer
GAP-009	IDENTIFY	ID.IM Improvement	**1**	2	**1**	R-002	P3	S	Chief Technology Officer
GAP-010	PROTECT	PR.AA Identity Management, Authentication and Access Control	**2**	3	**1**	R-001, R-003	P1	S	IT Operations Manager
GAP-011	PROTECT	PR.AT Awareness and Training	**1**	3	**2**	R-001	P1	M	Head of People and Operations
GAP-012	PROTECT	PR.DS Data Security	**2**	3	**1**	R-003, R-005	P1	M	Chief Technology Officer
GAP-013	PROTECT	PR.PS Platform Security	**0**	3	**3**	R-002, R-004	P1	M	Chief Technology Officer
GAP-014	PROTECT	PR.IR Technology Infrastructure Resilience	**0**	3	**3**	R-002, R-005	P1	M	IT Operations Manager
GAP-015	DETECT	DE.CM Continuous Monitoring	**1**	3	**2**	R-003, R-005	P1	M	IT Operations Manager
GAP-016	DETECT	DE.AE Adverse Event Analysis	**1**	2	**1**	R-001, R-003	P2	S	IT Operations Manager
GAP-017	RESPOND	RS.MA Incident Management	**2**	3	**1**	R-002, R-005	P1	S	Chief Technology Officer

Ref ID	Function	Category	Current	Target	Gap	Related Risk ID	Priority	Effort	Owner
GAP-018	RESPOND	RS.AN Incident Analysis	**1**	2	**1**	R-003, R-004	P2	S	IT Operations Manager
GAP-019	RESPOND	RS.CO Incident Response Reporting and Communication	**2**	3	**1**	R-005, R-003	P1	S	Head of Customer Success
GAP-020	RESPOND	RS.MI Incident Mitigation	**1**	2	**1**	R-001, R-002	P2	S	IT Operations Manager
GAP-021	RECOVER	RC.RP Incident Recovery Plan Execution	**1**	3	**2**	R-002	P1	S	IT Operations Manager
GAP-022	RECOVER	RC.CO Incident Recovery Communication	**0**	2	**2**	R-002, R-005	P2	S	Head of Customer Success
		OVERALL (22 Categories)	**1.23**	**2.68**	**1.45**				

Distribution of current scores:

Current score	Categories	Which
0	4	GV.SC, PR.PS, PR.IR, RC.CO
1	10	GV.OC, GV.OV, ID.AM, ID.IM, PR.AT, DE.CM, DE.AE, RS.AN, RS.MI, RC.RP
2	7	GV.RM, GV.RR, GV.PO, PR.AA, PR.DS, RS.MA, RS.CO
3	1	ID.RA

Three Categories score **0** or are close to it in the Functions that matter most for a SaaS company that ships code to a cloud platform — **PR.PS Platform Security (0)**, **PR.IR Technology Infrastructure Resilience (0)** and **GV.SC Supply Chain (0)**. One Category scores **3** — **ID.RA Risk Assessment** — and is the only place in the organisation where a control has been shown both to be designed and to have operated.

---

5. Detailed assessment — 22 Category findings

Each finding below carries all sixteen assessment columns in full.

FUNCTION: GOVERN

6 Categories assessed · average current 1.33 · target 2.67 · gap 1.33

GAP-001 — GV.OC Organizational Context

Category Description (NIST CSF 2.0). The circumstances - mission, stakeholder expectations, dependencies and legal, regulatory and contractual requirements - surrounding the organization's cybersecurity risk management decisions are understood.

Current State Observation. Cypher Group Inc. has no standalone document recording its mission, stakeholder expectations or its legal and contractual obligations. The only place this context exists is as assumptions A-01 to A-06 inside CGI-RSK-001, which record ARR of approximately USD 3.6M, roughly 200 SMB customers and the company's status as a GDPR data processor for customer account data; those assumptions were written to calibrate impact bands, not to serve as a governance record, and they have never been reviewed or approved as one. CGI-POL-004 §4.1.4 establishes that no cardholder numbers are held (formalised as AVD-001), which is the single clearest piece of scoping the company has, but no equivalent statement exists for GDPR processor obligations or for customer contractual security commitments.

Field	Value
Ref ID	GAP-001
Function	GOVERN
Category	GV.OC Organizational Context
Evidence Source	CGI-RSK-001 Assumptions A-01 to A-06; CGI-POL-004 §4.1.4; AVD-001
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	2 — Documented / Repeatable
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-005
Risk if Unaddressed	Security decisions are made without an agreed view of what the business actually owes its customers and regulators, so scope is argued case by case and enterprise security questionnaires cannot be answered consistently.
Priority	**P2**
Recommended Action	Publish a one-page Organizational Context and Compliance Obligations Register naming GDPR processor duties, customer contractual security commitments and the AVD-001 scope exclusion; approve it at CEO level and review annually.
Est. Effort	S (Small)
Owner (Job Title)	Chief Executive Officer
ISO 27001:2022 Annex A Mapping	A.5.1 Policies for information security; A.5.4 Management responsibilities; A.5.31 Legal, statutory, regulatory and contractual requirements

GAP-002 — GV.RM Risk Management Strategy

Category Description (NIST CSF 2.0). The organization's priorities, constraints, risk tolerance and appetite statements, and assumptions are established, communicated and used to support operational risk decisions.

Current State Observation. CGI-RSK-001 v1.0 establishes a documented NIST SP 800-30 Rev. 1 semi-quantitative 5x5 method with anchored likelihood and impact scales and published thresholds (Low 1-4, Medium 5-9, High 10-14, Critical 15-25), which is a genuine strategy artifact rather than an ad hoc exercise. However, no board- or CEO-approved risk appetite statement exists, so the thresholds describe how risk is measured but not how much of it Cypher Group Inc. has agreed to carry; the acceptance ACC-001 (SMS-based MFA exception, CTO-approved, expires 03 Mar 2027) was therefore approved against an undeclared appetite. The register also defines no executed re-assessment cadence - one cycle has been completed and none scheduled.

Field	Value
Ref ID	GAP-002
Function	GOVERN
Category	GV.RM Risk Management Strategy
Evidence Source	CGI-RSK-001 v1.0 § Methodology and Thresholds; ACC-001
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-004, R-005
Risk if Unaddressed	Risk acceptances are made by individuals against an undeclared tolerance, which is exactly how an organisation discovers after an incident that nobody formally decided anything.
Priority	**P1**
Recommended Action	Add a CEO-approved risk appetite statement and a defined annual plus event-driven re-assessment cadence to CGI-RSK-001 v1.1; re-confirm ACC-001 against the stated appetite before its 03 Mar 2027 expiry.
Est. Effort	S (Small)

Field	Value
Owner (Job Title)	Chief Executive Officer
ISO 27001:2022 Annex A Mapping	A.5.1 Policies for information security; A.5.4 Management responsibilities (supports ISO 27001 Clause 6.1 risk planning)

GAP-003 — GV.RR Roles, Responsibilities and Authorities

Category Description (NIST CSF 2.0). Cybersecurity roles, responsibilities and authorities to foster accountability, performance assessment and continuous improvement are established and communicated.

Current State Observation. Ownership is assigned at document level and is genuinely traceable: CGI-POL-001 is owned by the Head of People and Operations, CGI-POL-002 and CGI-POL-004 by the CTO, and every risk in CGI-RSK-001 carries a named business risk owner rather than a generic security owner. What does not exist is any security-specific role, any RACI covering the ten treatment actions TP-01 to TP-10, or any allocated security budget beyond the USD 32,100 year-one figure estimated in CGI-RSK-001, which was costed but never formally approved. Accountability therefore exists per artifact but not as an operating structure, and no individual holds day-to-day responsibility for the programme between projects.

Field	Value
Ref ID	GAP-003
Function	GOVERN
Category	GV.RR Roles, Responsibilities and Authorities
Evidence Source	CGI-POL-001 to CGI-POL-005 document control blocks; CGI-RSK-001 risk owner column; CGI-RSK-001 TP-01 to TP-10
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-003
Risk if Unaddressed	Controls have owners on paper but no one is accountable for the programme between assessments, so remediation stalls the moment the assessment ends.
Priority	**P2**
Recommended Action	Publish a security RACI covering all 22 CSF Categories and TP-01 to TP-10, formally assign the security programme lead duty to the CTO, and obtain CEO approval of the USD 32,100 year-one budget.
Est. Effort	S (Small)
Owner (Job Title)	Chief Executive Officer
ISO 27001:2022 Annex A Mapping	A.5.2 Information security roles and responsibilities; A.5.3 Segregation of duties; A.5.4 Management responsibilities

GAP-004 — GV.PO Policy

Category Description (NIST CSF 2.0). Organizational cybersecurity policy is established, communicated and enforced.

Current State Observation. This is the company's strongest documented area and the direct output of Project 1: CGI-POL-001 to CGI-POL-005 v1.0 are written, approved by Jerry Gold and published, covering acceptable use, password and MFA, joiner-mover-leaver access control, data classification and incident reporting, with an Exception Register carrying EXC-001 to EXC-003. Enforcement is the gap, not authorship. CGI-TRK-001 evidences only 60% policy acknowledgement across 50 employees, meaning roughly 20 staff are bound by policies they have not read; the annual review cycle mandated in each policy's document control block has not yet run once, so no policy has a demonstrated review record. Three policies identified as necessary in CGI-RSK-001 - CGI-POL-006 Backup and Recovery, CGI-POL-007 Secure Development and Change Management and CGI-POL-008 Vulnerability Management - remain unwritten.

Field	Value
Ref ID	GAP-004
Function	GOVERN
Category	GV.PO Policy
Evidence Source	CGI-POL-001 to CGI-POL-005 v1.0; CGI-TRK-001 (60% acknowledged); EXC-001 to EXC-003; CGI-RSK-001 recommended policies
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-001, R-002
Risk if Unaddressed	An unacknowledged policy is unenforceable in a disciplinary process and worthless as audit evidence, so the entire Project 1 investment fails to convert into risk reduction.
Priority	**P1**
Recommended Action	Drive CGI-TRK-001 acknowledgement from 60% to 100% with an onboarding completion gate, execute and record the first annual review of all five policies, and publish CGI-POL-006, CGI-POL-007 and CGI-POL-008.
Est. Effort	S (Small)
Owner (Job Title)	Chief Technology Officer
ISO 27001:2022 Annex A Mapping	A.5.1 Policies for information security; A.5.36 Compliance with policies, rules and standards; A.5.37 Documented operating procedures

GAP-005 — GV.OV Oversight

Category Description (NIST CSF 2.0). Results of organization-wide cybersecurity risk management activities and performance are used to inform, improve and adjust the risk management strategy.

Current State Observation. CGI-RSK-001 defines seven Key Risk Indicators with thresholds and named owners, which is the raw material for oversight, but not one of them has ever been measured or reported; no management review of the security programme has taken place, and no security item has appeared on a leadership agenda with minutes. The 52% inherent-to-residual risk reduction attributable to the Project 1 policy pack (aggregate 92 to 44, mean 18.4 to 8.8) is a strong, defensible performance figure that has never been presented to Jerry Gold, so leadership has no basis on which to adjust strategy or release the USD 32,100 budget.

Field	Value
Ref ID	GAP-005
Function	GOVERN
Category	GV.OV Oversight
Evidence Source	CGI-RSK-001 KRI table (7 KRIs, unreported); no management review minutes on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	3 — Defined and Operating
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-004, R-005
Risk if Unaddressed	Leadership cannot fund, redirect or defend a programme whose performance it never sees, so security investment competes on anecdote rather than evidence.
Priority	**P2**
Recommended Action	Establish a minuted quarterly security review with Jerry Gold reporting the seven CGI-RSK-001 KRIs, this maturity scorecard and TP-01 to TP-10 status; retain the minutes as the oversight evidence record.
Est. Effort	S (Small)
Owner (Job Title)	Chief Executive Officer

Field	Value
ISO 27001:2022 Annex A Mapping	A.5.35 Independent review of information security; A.5.36 Compliance with policies, rules and standards (supports Clause 9.3 Management review)

GAP-006 — GV.SC Cybersecurity Supply Chain Risk Management

Category Description (NIST CSF 2.0). Cyber supply chain risk management processes are identified, established, managed, monitored and improved by organizational stakeholders.

Current State Observation. Nothing exists in this Category beyond two fragments. Cypher Group Inc. runs its production stack on five known third parties - CloudCo for hosting, CodeCo for source code, ChatCo for communications, OfficeCo for email and documents and PaymentsCo for payment metadata - and none has been security-assessed, none has a recorded assurance artifact such as a SOC 2 report or ISO 27001 certificate on file, and no data processing agreements are tracked in a register. CGI-POL-004 §4.2 Handling Matrix specifies how classified data must be handled but names no permitted or prohibited third-party destinations, so a Confidential record may be pasted into an unvetted SaaS tool without breaching any written rule. The two fragments are CGI-POL-001 §4.6.1, which requires CTO approval before any new third-party service is used, and CGI-POL-003 §4.6, which requires a named sponsor and an expiry date for third-party user access. Neither has an inventory, a tiering rule, an assessment method or an execution record behind it, so under the fragment rule in §3.1 the Category stays at 0. This Category is also entirely outside the scope of CGI-RSK-001, which assessed no supplier-originated scenario.

Field	Value
Ref ID	GAP-006
Function	GOVERN
Category	GV.SC Cybersecurity Supply Chain Risk Management
Evidence Source	No vendor inventory on file; CGI-POL-004 §4.2 (no third-party destinations named); CGI-POL-001 §4.6.1 and CGI-POL-003 §4.6 (fragments only); CGI-RSK-001 scope statement
Current Score (0–4)	**0** — Not Performed
Target Score (0–4)	2 — Documented / Repeatable
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-005
Risk if Unaddressed	A compromise at CloudCo, CodeCo or OfficeCo would reach all customer data with no contractual remedy, no assessed control baseline and no notification pathway; enterprise buyers treat a missing vendor register as a hard fail.
Priority	**P1**
Recommended Action	Build a tiered vendor inventory covering CloudCo, CodeCo, ChatCo, OfficeCo and PaymentsCo with data classification exposure, collect each provider's assurance artifact and DPA, and add permitted third-party destinations to CGI-POL-004 §4.2. (Delivered 15 Sep 2026 as Project 4 (CGI-TPR-001), three quarters ahead of its Q2 2027 slot.)
Est. Effort	M (Medium)
Owner (Job Title)	Chief Technology Officer
ISO 27001:2022 Annex A Mapping	A.5.19 Information security in supplier relationships; A.5.20 Addressing information security within supplier agreements; A.5.21 Managing information security in the ICT supply chain; A.5.22 Monitoring, review and change management of supplier services; A.5.23 Information security for use of cloud services

FUNCTION: IDENTIFY

3 Categories assessed · average current 1.67 · target 2.67 · gap 1.00

GAP-007 — ID.AM Asset Management

Category Description (NIST CSF 2.0). Assets - data, hardware, software, systems, facilities, services and people - that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy.

Current State Observation. CGI-POL-004 establishes a four-tier data classification scheme with a §4.2 Handling Matrix and a §4.1.3 aggregation rule, so Cypher Group Inc. knows what its data is worth in principle, but there is no inventory recording where any of it actually lives. No list exists of CloudCo accounts and their S3 buckets and RDS instances, CodeCo repositories, OfficeCo shared drives, ChatCo channels or PaymentsCo objects, and no endpoint register exists for the 50 staff devices governed by CGI-POL-001 §4.4 BYOD. The classification scheme is therefore unapplied: no asset carries a classification label, which means the Handling Matrix cannot be enforced or audited against anything.

Field	Value
Ref ID	GAP-007
Function	IDENTIFY
Category	ID.AM Asset Management
Evidence Source	CGI-POL-004 §4.1 to §4.2; CGI-POL-001 §4.4 (BYOD, no device register); no asset inventory on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	3 — Defined and Operating
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-003, R-005
Risk if Unaddressed	You cannot protect, monitor, review access to or restore an asset you have not recorded; the absence of an inventory is the root blocker under access review, cloud hardening, monitoring and recovery alike.
Priority	**P1**
Recommended Action	Build an asset and SaaS inventory covering CloudCo accounts and data stores, CodeCo repositories, OfficeCo shared drives, ChatCo workspaces, PaymentsCo objects and staff endpoints, and apply a CGI-POL-004 classification label to every entry.
Est. Effort	M (Medium)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.5.9 Inventory of information and other associated assets; A.5.10 Acceptable use of information and other associated assets; A.5.12 Classification of information; A.5.13 Labelling of information; A.8.1 User endpoint devices

GAP-008 — ID.RA Risk Assessment

Category Description (NIST CSF 2.0). The cybersecurity risk to the organization, assets and individuals is understood by the organization.

Current State Observation. This is the only Category at Cypher Group Inc. that demonstrates both design and operating effectiveness. CGI-RSK-001 v1.0 was performed end to end using NIST SP 800-30 Rev. 1, documents five scenarios (R-001 to R-005) in full threat-source to business-consequence form, records both inherent (20/20/12/20/20) and residual (6/8/6/12/12) scores, cites a specific CGI-POL clause for every mitigating control across more than 60 clause-level cross-references, applies all four treatment strategies including a formally documented acceptance and avoidance, and was approved by Jerry Gold. It is scored 3 rather than 4 because no metrics govern the process and because the identification input is incomplete: CSF Subcategory ID.RA-01 requires vulnerabilities in assets to be identified, and Cypher Group Inc. performs no vulnerability scanning of any kind (control gap CG-02), so the register's coverage rests on workshop judgement rather than on technical discovery.

Field	Value
Ref ID	GAP-008
Function	IDENTIFY

Field	Value
Category	ID.RA Risk Assessment
Evidence Source	CGI-RSK-001 v1.0 (approved, Jerry Gold); R-001 to R-005; CG-01 to CG-05; TP-01 to TP-10
Current Score (0–4)	**3** — Defined and Operating
Target Score (0–4)	3 — Defined and Operating
Gap	**0**
Related Risk ID (CGI-RSK-001)	R-001, R-002, R-003, R-004, R-005
Risk if Unaddressed	Coverage gaps persist: without vulnerability scanning the register can only contain risks a human thought of, so a technically discoverable exposure can sit outside the register indefinitely.
Priority	**P2**
Recommended Action	Maintain the annual and event-driven cadence, and feed authenticated vulnerability scan output into the next CGI-RSK-001 revision so that ID.RA-01 is satisfied by technical discovery rather than judgement alone.
Est. Effort	S (Small)
Owner (Job Title)	Chief Technology Officer
ISO 27001:2022 Annex A Mapping	A.5.7 Threat intelligence; A.8.8 Management of technical vulnerabilities (supports Clause 6.1.2 Information security risk assessment)

GAP-009 — ID.IM Improvement

Category Description (NIST CSF 2.0). Improvements to organizational cybersecurity risk management processes, procedures and activities are identified across all CSF Functions.

Current State Observation. A forward-looking improvement plan exists in the form of treatment actions TP-01 to TP-10 in CGI-RSK-001, each with an owner and an estimated cost, which is more than most companies of this size have. The backward-looking loop is written only for incidents: CGI-POL-005 §5.7 requires a blameless post-incident review with tracked corrective actions and a decision on whether any policy needs amending, and §7.2 requires an annual tabletop exercise. Neither has ever run: no incident has been recorded, so no review or lessons-learned record exists, and no tabletop has been held. Outside incident response there is no written improvement loop at all, and nothing requires findings from assessments, red KRIs or expired exceptions in EXC-001 to EXC-003 to lead to a recorded change. Because the written clauses cover only the incident part of the Category and have never operated, the Category is scored down to 1 under §3.1. Improvement is currently something that happens when a project is commissioned, not something the organisation does.

Field	Value
Ref ID	GAP-009
Function	IDENTIFY
Category	ID.IM Improvement
Evidence Source	CGI-RSK-001 TP-01 to TP-10; CGI-POL-005 §5.7 and §7.2 (written, never exercised); EXC-001 to EXC-003
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	2 — Documented / Repeatable
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-002
Risk if Unaddressed	The same failure recurs because nothing forces the organisation to learn from it; exceptions become permanent by default rather than by decision.
Priority	**P3**
Recommended Action	Run the first CGI-POL-005 §7.2 tabletop exercise and keep a written lessons-learned record, log every §5.7 post-incident review in the incident register, and add a rule that every expired exception in EXC-001 to EXC-003 and every red KRI produces a recorded improvement decision.

Field	Value
Est. Effort	S (Small)
Owner (Job Title)	Chief Technology Officer
ISO 27001:2022 Annex A Mapping	A.5.27 Learning from information security incidents (supports Clause 10.1 Continual improvement and Clause 10.2 Nonconformity and corrective action)

FUNCTION: PROTECT

5 Categories assessed · average current 1.00 · target 3.00 · gap 2.00

GAP-010 — PR.AA Identity Management, Authentication and Access Control

Category Description (NIST CSF 2.0). Access to physical and logical assets is limited to authorized users, services and hardware, and is managed commensurate with the assessed risk of unauthorized access.

Current State Observation. The written control set here is strong and specific. CGI-POL-002 §4.3.3 mandates phishing-resistant MFA for privileged accounts, §4.3.5 prohibits SMS as a factor, and §4.5 governs service accounts and secrets, all aligned to NIST SP 800-63B-4; CGI-POL-003 §4.5.2 requires access revocation within four hours of a leaver event and §4.7.1 mandates a quarterly privileged access review. Operation is where it fails. CGI-TRK-001 evidences 80% MFA enrolment, leaving roughly ten accounts unprotected; ACC-001 formally accepts continued SMS-based MFA in direct tension with §4.3.5 until 03 Mar 2027; and CGI-TRK-001 evidences no completed quarterly privileged access review against the §4.7.1 mandate, so the control is documented but has never operated. The four-hour revocation SLA in §4.5.2 has likewise never been measured against an actual leaver event.

Field	Value
Ref ID	GAP-010
Function	PROTECT
Category	PR.AA Identity Management, Authentication and Access Control
Evidence Source	CGI-POL-002 §4.3.3, §4.3.5, §4.5; CGI-POL-003 §4.5.2, §4.7.1; CGI-TRK-001 (80% MFA, zero completed access reviews); ACC-001
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-001, R-003
Risk if Unaddressed	CGI-RSK-001 already discounts the residual 6 on R-001 for incomplete MFA coverage. Roughly ten unprotected accounts and an unexecuted privileged access review are what stop it falling to its target of 3, and each one is a live route to credential compromise.
Priority	**P1**
Recommended Action	Complete MFA enrolment to 100% and retire ACC-001 ahead of its 03 Mar 2027 expiry, then execute and evidence the first quarterly privileged access review required by CGI-POL-003 §4.7.1.
Est. Effort	S (Small)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.5.15 Access control; A.5.16 Identity management; A.5.17 Authentication information; A.5.18 Access rights; A.8.2 Privileged access rights; A.8.5 Secure authentication

GAP-011 — PR.AT Awareness and Training

Category Description (NIST CSF 2.0). The organization's personnel are provided with cybersecurity awareness and training so that they can perform their cybersecurity-related tasks.

Current State Observation. Awareness at Cypher Group Inc. is induction-only. CGI-POL-003 §4.3.6 requires security awareness induction within 10 business days of joining, and CGI-TRK-001 records 60% completion alongside 60% policy acknowledgement. Nothing follows the induction: there is no recurring curriculum, no role-specific training for engineers with production access, and no phishing simulation programme, which CGI-RSK-001 records as control gap CG-04. Because role-based training (PR.AT-02) is not performed at all and the induction mandate is only partly evidenced, the Category is scored down to 1. This undercuts the treatment of R-001, whose residual score of 6 is credited in part to user vigilance that has been trained once, at induction, and never tested. CGI-POL-001 §4.5 introduces AI usage controls, a genuinely current risk area, that no employee has received any instruction on.

Field	Value
Ref ID	GAP-011
Function	PROTECT
Category	PR.AT Awareness and Training
Evidence Source	CGI-POL-003 §4.3.6; CGI-TRK-001 (60% acknowledged, 60% induction training complete); CGI-RSK-001 CG-04; CGI-POL-001 §4.5
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	3 — Defined and Operating
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-001
Risk if Unaddressed	Phishing is one of four scenarios at the register's highest inherent score (R-001, inherent 20), and its principal control is human judgement that has been trained once and never measured or tested.
Priority	**P1**
Recommended Action	Stand up an annual security awareness curriculum with an induction module and role-specific content for staff with production access, plus quarterly phishing simulations with click and report rates tracked in CGI-TRK-001 as a KRI.
Est. Effort	M (Medium)
Owner (Job Title)	Head of People and Operations
ISO 27001:2022 Annex A Mapping	A.6.3 Information security awareness, education and training; A.6.8 Information security event reporting

GAP-012 — PR.DS Data Security

Category Description (NIST CSF 2.0). Data is managed consistent with the organization's risk strategy to protect the confidentiality, integrity and availability of information.

Current State Observation. CGI-POL-004 gives Cypher Group Inc. a well-built classification foundation - four tiers, a §4.2 Handling Matrix, a §4.1.3 aggregation rule and the §4.1.4 decision to hold no cardholder numbers, formalised as the avoidance AVD-001, which is a genuine architectural risk reduction rather than a paper control. Beyond classification the Category is unimplemented: no encryption standard names required algorithms or key management for data at rest in CloudCo or in transit, no retention or secure deletion schedule has been executed, and no data loss prevention or egress monitoring exists on OfficeCo or CodeCo, which CGI-RSK-001 records as control gap CG-05 and which is the reason R-003 retains a residual score of 6 despite the JML controls in CGI-POL-003.

Field	Value
Ref ID	GAP-012
Function	PROTECT
Category	PR.DS Data Security
Evidence Source	CGI-POL-004 §4.1.3, §4.1.4, §4.2; AVD-001; CGI-RSK-001 CG-05
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating

Field	Value
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-003, R-005
Risk if Unaddressed	Classified data can leave the organisation through an ordinary download or repository clone with no technical barrier and no record that it happened, making the insider scenario R-003 undetectable rather than merely unprevented.
Priority	**P1**
Recommended Action	Publish an encryption standard covering CloudCo data at rest and in transit with named algorithms and key management, define and execute a retention and secure deletion schedule, and deploy data egress monitoring on OfficeCo and CodeCo.
Est. Effort	M (Medium)
Owner (Job Title)	Chief Technology Officer
ISO 27001:2022 Annex A Mapping	A.5.12 Classification of information; A.5.14 Information transfer; A.8.10 Information deletion; A.8.11 Data masking; A.8.12 Data leakage prevention; A.8.24 Use of cryptography

GAP-013 — PR.PS Platform Security

Category Description (NIST CSF 2.0). The hardware, software and services of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity and availability.

Current State Observation. This Category scores zero and shares the largest gap in the assessment with PR.IR. Cypher Group Inc. builds and ships a B2B SaaS product from CodeCo to CloudCo with no secure development lifecycle whatsoever: no secure development or change management policy exists, CGI-POL-007 having been recommended in CGI-RSK-001 but never written; there is no mandatory peer code review, no branch protection on the repositories holding production code, no separation of development and production environments on record, and no application security testing. There is equally no vulnerability management for the platform: no scanning, no severity-based remediation SLA and no server configuration baseline, with CGI-POL-008 likewise recommended and unwritten. CGI-RSK-001 records both halves as control gap CG-02. Two fragments exist and were weighed: CGI-POL-001 §4.4.3 requires endpoint operating-system and browser patches within 14 days, and CGI-POL-002 §4.5.2 requires CodeCo secret scanning and push protection. Neither governs how code is reviewed, tested or released, so under the fragment rule in §3.1 the Category stays at 0. The entire Project 1 policy pack contains no clause governing how code reaches production, which is precisely why R-004 remains at residual High.

Field	Value
Ref ID	GAP-013
Function	PROTECT
Category	PR.PS Platform Security
Evidence Source	CGI-RSK-001 CG-02; CGI-POL-007 and CGI-POL-008 recommended, not written; CGI-POL-001 §4.4.3 and CGI-POL-002 §4.5.2 (fragments only); no branch protection or scan evidence on file
Current Score (0–4)	**0** — Not Performed
Target Score (0–4)	3 — Defined and Operating
Gap	**3**
Related Risk ID (CGI-RSK-001)	R-002, R-004
Risk if Unaddressed	R-004 (production API authorisation flaw) stays at residual 12, High, after treatment because no control in the policy pack touches the code path; an authorisation defect can reach approximately 200 customers' data with nothing standing between the commit and production.
Priority	**P1**
Recommended Action	Publish CGI-POL-007 and enforce CodeCo branch protection with mandatory peer review and no direct commits to main; publish CGI-POL-008 and begin authenticated vulnerability scanning with severity-based remediation SLAs.
Est. Effort	M (Medium)

Field	Value
Owner (Job Title)	Chief Technology Officer
ISO 27001:2022 Annex A Mapping	A.8.8 Management of technical vulnerabilities; A.8.9 Configuration management; A.8.25 Secure development life cycle; A.8.28 Secure coding; A.8.29 Security testing in development and acceptance; A.8.31 Separation of development, test and production environments; A.8.32 Change management

GAP-014 — PR.IR Technology Infrastructure Resilience

Category Description (NIST CSF 2.0). Security architectures are managed with the organization's risk strategy to protect asset confidentiality, integrity and availability, and organizational resilience.

Current State Observation. This Category also scores zero. There is no documented CloudCo configuration baseline, no benchmark such as CIS AWS Foundations has been applied, no continuous cloud security posture monitoring is enabled, and no network segmentation or production access boundary is recorded anywhere - collectively control gap CG-03 in CGI-RSK-001. Backups exist as CloudCo native snapshots but no restore has ever been tested and no RTO or RPO has been declared, so the company holds a backup but has never demonstrated a recovery capability; CGI-POL-006 Backup and Recovery was recommended in CGI-RSK-001 and has not been written (control gap CG-01). No policy in the CGI-POL-001 to CGI-POL-005 pack addresses cloud configuration at all, which is the documented reason R-005 remains at residual High.

Field	Value
Ref ID	GAP-014
Function	PROTECT
Category	PR.IR Technology Infrastructure Resilience
Evidence Source	CGI-RSK-001 CG-01, CG-03; CGI-POL-006 recommended, not written; no CIS baseline or restore test evidence on file
Current Score (0–4)	**0** — Not Performed
Target Score (0–4)	3 — Defined and Operating
Gap	**3**
Related Risk ID (CGI-RSK-001)	R-002, R-005
Risk if Unaddressed	R-005 (CloudCo misconfiguration leading to public data exposure) stays at residual 12, High, after treatment; a single permissive S3 or security group change exposes customer data with no baseline to deviate from and no posture monitoring to catch it.
Priority	**P1**
Recommended Action	Apply a CIS AWS Foundations Benchmark baseline and enable continuous posture monitoring; publish CGI-POL-006 with declared RTO and RPO and evidence a successful restore test; document network segmentation and production access boundaries.
Est. Effort	M (Medium)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.8.9 Configuration management; A.8.13 Information backup; A.8.14 Redundancy of information processing facilities; A.8.20 Networks security; A.8.22 Segregation of networks

FUNCTION: DETECT

2 Categories assessed · average current 1.00 · target 2.50 · gap 1.50

GAP-015 — DE.CM Continuous Monitoring

Category Description (NIST CSF 2.0). Assets are monitored to find anomalies, indicators of compromise and other potentially adverse events.

Current State Observation. Cypher Group Inc. has established the legal right to monitor without building the ability to do so. CGI-POL-001 §4.10 contains a properly drafted monitoring notice giving the company a lawful basis to inspect activity on its systems, but no monitoring capability exists behind it: AWS CloudTrail coverage and log file validation are unverified across regions, there is no centralised security log destination (engineering uses MonitorCo, CGI-VEN-007, for application performance monitoring, but it is not configured or retained as a security log source), no alerting on root account usage or IAM policy changes, no endpoint detection on the 50 staff devices and no monitoring of data egress from OfficeCo or CodeCo. CGI-RSK-001 records the cloud half of this as control gap CG-03 (no drift detection) and the data-egress half as CG-05, and together they are the reason both R-003 and R-005 retain elevated residual positions - neither insider exfiltration nor a cloud misconfiguration would be observed as it occurred.

Field	Value
Ref ID	GAP-015
Function	DETECT
Category	DE.CM Continuous Monitoring
Evidence Source	CGI-POL-001 §4.10 (monitoring notice, no capability); CGI-RSK-001 CG-03, CG-05; no centralised logging on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	3 — Defined and Operating
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-003, R-005
Risk if Unaddressed	The company would learn about a breach from a customer, a researcher or a regulator rather than from its own systems, which converts a containable incident into a disclosed one and starts the GDPR 72-hour clock from someone else's discovery.
Priority	**P1**
Recommended Action	Enable AWS CloudTrail organisation-wide with log file validation, centralise logs to a dedicated account with defined retention, and alert on root account usage, IAM policy change, public S3 exposure and mass data download.
Est. Effort	M (Medium)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.8.15 Logging; A.8.16 Monitoring activities; A.8.12 Data leakage prevention

GAP-016 — DE.AE Adverse Event Analysis

Category Description (NIST CSF 2.0). Anomalies, indicators of compromise and other potentially adverse events are analyzed to characterize the events and detect cybersecurity incidents.

Current State Observation. CGI-POL-005 provides the classification half of this Category properly: SEV1 to SEV4 severity bands are defined with criteria, so an event that is reported would be triaged consistently against a written standard. Everything upstream of that is absent. There is no correlation of events across CloudCo, CodeCo, OfficeCo and ChatCo, no alert thresholds, no defined escalation from an alert to a declared incident, and because DE.CM produces no telemetry there is nothing to analyse in the first place. In practice the only detection route available to Cypher Group Inc. is a human noticing something and reporting it through the CGI-POL-005 channel.

Field	Value
Ref ID	GAP-016
Function	DETECT
Category	DE.AE Adverse Event Analysis
Evidence Source	CGI-POL-005 SEV1 to SEV4 definitions; CGI-RSK-001 CG-03, CG-05; no alerting or correlation on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	2 — Documented / Repeatable

Field	Value
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-001, R-003
Risk if Unaddressed	Severity bands are meaningless without inputs to classify; incidents are characterised only after they have become visible for some other reason, by which point containment options have narrowed.
Priority	**P2**
Recommended Action	Define alert thresholds and a written escalation path from alert to declared incident mapped onto the CGI-POL-005 SEV1 to SEV4 bands, once centralised logging from the DE.CM action is in place.
Est. Effort	S (Small)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.5.25 Assessment and decision on information security events; A.8.15 Logging; A.8.16 Monitoring activities

FUNCTION: RESPOND

4 Categories assessed · average current 1.50 · target 2.50 · gap 1.00

GAP-017 — RS.MA Incident Management

Category Description (NIST CSF 2.0). Responses to detected cybersecurity incidents are managed.

Current State Observation. CGI-POL-005 is an approved incident reporting policy aligned to NIST SP 800-61 Rev. 3, defining SEV1 to SEV4 bands with acknowledgement and containment targets (§5.4), reporting channels (§5.2), named response roles (§4) and a staged response process (§5.5), and it is a real control rather than a placeholder. It has, however, never been exercised: no incident has been recorded, no tabletop or simulation has been run, the §4 roles have never been rehearsed, and no containment, eradication or recovery runbooks exist beneath the policy's one-line stage descriptions. None of the timing commitments - the §5.4 containment targets or the four-hour access revocation SLA in CGI-POL-003 §4.5.2 - has ever been tested. An untested response plan is a design-effectiveness control only.

Field	Value
Ref ID	GAP-017
Function	RESPOND
Category	RS.MA Incident Management
Evidence Source	CGI-POL-005 v1.0 (approved, never exercised); CGI-POL-003 §4.5.2; no incident or exercise records in CGI-TRK-001
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-002, R-005
Risk if Unaddressed	First contact with the plan happens during a real SEV1, when discovering that roles, authority to act and escalation contacts were never rehearsed costs hours that the GDPR 72-hour clock is already consuming.
Priority	**P1**
Recommended Action	Run a SEV1 tabletop exercise against CGI-POL-005 covering a ransomware and a cloud exposure scenario, rehearse the §4 response roles, and write containment and eradication runbooks for the top three scenarios in CGI-RSK-001.
Est. Effort	S (Small)
Owner (Job Title)	Chief Technology Officer

Field	Value
ISO 27001:2022 Annex A Mapping	A.5.24 Information security incident management planning and preparation; A.5.26 Response to information security incidents

GAP-018 — RS.AN Incident Analysis

Category Description (NIST CSF 2.0). Investigations are conducted to ensure effective response and support forensics and recovery activities.

Current State Observation. Cypher Group Inc. currently has no ability to investigate an incident after the fact. CGI-POL-005 §5.3.2 forbids deleting evidence and §5.7.3 requires a root cause analysis, but there is no forensic readiness, no evidence collection or chain-of-custody procedure beneath those clauses, and critically no log retention standard, so even where logs exist they may be rotated away before an investigation begins - the same gaps (CG-03, CG-05) that block detection also block analysis. The analysis stage is written but cannot be performed as designed, which is why the Category is scored 1 rather than 2. Root cause determination would rest on the recollection of whoever was present. For a company processing customer account data under GDPR this also undermines the accuracy of any Article 33 notification, since the scope of a breach could not be established with evidence.

Field	Value
Ref ID	GAP-018
Function	RESPOND
Category	RS.AN Incident Analysis
Evidence Source	CGI-POL-005 §5.3.2, §5.7.3 (no collection procedure beneath them); CGI-RSK-001 CG-03, CG-05; no log retention standard on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	2 — Documented / Repeatable
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-003, R-004
Risk if Unaddressed	Breach scope cannot be established, so the company must either under-report and risk regulatory sanction or over-report and damage roughly 200 customer relationships unnecessarily.
Priority	**P2**
Recommended Action	Add an evidence collection and chain-of-custody procedure to CGI-POL-005 and define a minimum log retention period of twelve months for authentication, administrative and data access events across CloudCo, CodeCo and OfficeCo.
Est. Effort	S (Small)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.5.27 Learning from information security incidents; A.5.28 Collection of evidence; A.8.15 Logging

GAP-019 — RS.CO Incident Response Reporting and Communication

Category Description (NIST CSF 2.0). Response activities are coordinated with internal and external stakeholders as required by laws, regulations or policies.

Current State Observation. CGI-POL-005 §5.6.3 correctly captures the GDPR Article 33 obligation to notify the supervisory authority within 72 hours of becoming aware of a personal data breach, which is the single most consequential external commitment the company has made in writing. The policy also names the Head of Customer Success as Communications Lead (§4, §5.6.1), sets CEO escalation times by severity (§5.4) and a 72-hour default for customer notification (§5.6.2). The supporting machinery does not exist: there is no identified lead supervisory authority and no regulator contact record, no customer or regulator notification templates, no deputy for the Communications Lead, and the 72-hour path has never been rehearsed. The obligation is documented; the ability to meet it inside 72 hours is not evidenced.

Field	Value
Ref ID	GAP-019
Function	RESPOND
Category	RS.CO Incident Response Reporting and Communication
Evidence Source	CGI-POL-005 §4, §5.4, §5.6.1 to §5.6.3; no regulator contact record or notification templates on file
Current Score (0–4)	**2** — Documented / Repeatable
Target Score (0–4)	3 — Defined and Operating
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-005, R-003
Risk if Unaddressed	A 72-hour statutory deadline that has never been rehearsed is routinely missed in practice, and a missed or inaccurate notification converts a security incident into a regulatory enforcement matter.
Priority	**P1**
Recommended Action	Identify and record the lead supervisory authority and contact route, produce customer and regulator notification templates, name a deputy for the Communications Lead, and rehearse the 72-hour path in the RS.MA tabletop.
Est. Effort	S (Small)
Owner (Job Title)	Head of Customer Success
ISO 27001:2022 Annex A Mapping	A.5.5 Contact with authorities; A.5.6 Contact with special interest groups; A.5.24 Information security incident management planning and preparation; A.6.8 Information security event reporting

GAP-020 — RS.MI Incident Mitigation

Category Description (NIST CSF 2.0). Activities are performed to prevent expansion of an event and mitigate its effects.

Current State Observation. The one genuine containment capability Cypher Group Inc. has is the four-hour access revocation requirement in CGI-POL-003 §4.5.2, written for the leaver process rather than for incident response but usable in a credential compromise. CGI-POL-005 §5.5.1 names containment as a stage (disable accounts, rotate credentials, isolate systems) and CGI-POL-002 §4.5.3 requires a committed secret to be rotated, but nothing sits beneath those lines: there are no runbooks for isolating a compromised CloudCo resource, revoking active sessions or rotating credentials and secrets at speed, no anti-malware standard covering the 50 staff endpoints, and no pre-agreed authority for an engineer to take production action without approval during a live incident. Containment would therefore be improvised under pressure by whoever holds CloudCo credentials. The policy states what containment is but not how to do it, so the Category is scored down to 1.

Field	Value
Ref ID	GAP-020
Function	RESPOND
Category	RS.MI Incident Mitigation
Evidence Source	CGI-POL-003 §4.5.2; CGI-POL-005 §5.5.1; CGI-POL-002 §4.5.3 (no rotation runbook); no containment runbooks on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	2 — Documented / Repeatable
Gap	**1**
Related Risk ID (CGI-RSK-001)	R-001, R-002
Risk if Unaddressed	Ransomware (R-002, inherent 20) and credential compromise (R-001, inherent 20) both spread on a timescale of minutes, and improvised containment during a live incident is how a contained event becomes a company-wide one.

Field	Value
Priority	**P2**
Recommended Action	Write containment runbooks for credential compromise, ransomware and cloud exposure covering session revocation, credential and secret rotation and resource isolation, and pre-authorise named engineers to act during a declared SEV1 without waiting for approval.
Est. Effort	S (Small)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.5.26 Response to information security incidents; A.8.7 Protection against malware

FUNCTION: RECOVER

2 Categories assessed · average current 0.50 · target 2.50 · gap 2.00

GAP-021 — RC.RP Incident Recovery Plan Execution

Category Description (NIST CSF 2.0). Restoration activities are performed to ensure operational availability of systems and services affected by cybersecurity incidents.

Current State Observation. Backups exist as CloudCo native snapshots, which is why this Category scores 1 rather than 0, but no restore has ever been tested, no recovery time objective or recovery point objective has been declared, no recovery plan document exists and no recovery roles have been assigned. CGI-POL-006 Backup and Recovery was identified as necessary in CGI-RSK-001 and has not been written, and the absence of tested recovery is control gap CG-01. An untested backup is not a recovery capability, it is an assumption - which is why CGI-RSK-001 deliberately gives R-002 no credit for backups and holds its residual impact at 4 until CG-01 is closed. This assessment reaches the same conclusion from the other direction.

Field	Value
Ref ID	GAP-021
Function	RECOVER
Category	RC.RP Incident Recovery Plan Execution
Evidence Source	CGI-RSK-001 CG-01 and R-002 residual rationale; CGI-POL-006 recommended, not written; no restore test record on file
Current Score (0–4)	**1** — Initial / Ad Hoc
Target Score (0–4)	3 — Defined and Operating
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-002
Risk if Unaddressed	In a ransomware event the company would discover whether its backups restore at the worst possible moment, and an unrecoverable SaaS platform is an existential rather than a financial event for roughly 200 customers.
Priority	**P1**
Recommended Action	Perform and document a full restore test to a clean environment, publish CGI-POL-006 with declared RTO and RPO approved by Jerry Gold, and schedule the restore test to repeat every six months as a KRI.
Est. Effort	S (Small)
Owner (Job Title)	IT Operations Manager
ISO 27001:2022 Annex A Mapping	A.5.29 Information security during disruption; A.5.30 ICT readiness for business continuity; A.8.13 Information backup

GAP-022 — RC.CO Incident Recovery Communication

Category Description (NIST CSF 2.0). Restoration activities are coordinated with internal and external parties.

Current State Observation. Nothing exists in this Category beyond a fragment. Cypher Group Inc. has no customer communication plan for a service disruption or breach, no status page or equivalent channel through which roughly 200 SMB customers could be informed of an outage and its resolution, no holding statements prepared, and no defined point at which recovery is declared complete and communicated. CGI-POL-005 makes the Head of Customer Success the Communications Lead for all external incident communication (§5.6.1) and sets a deadline for notifying customers of a breach (§5.6.2), but nothing addresses communicating recovery: progress updates, the all-clear, or what was done. Under the fragment rule in §3.1, a general communications owner does not lift the Category off 0.

Field	Value
Ref ID	GAP-022
Function	RECOVER
Category	RC.CO Incident Recovery Communication
Evidence Source	CGI-POL-005 §5.6.1 to §5.6.3 (breach notification only - a fragment); no status page or customer communication plan on file
Current Score (0–4)	**0** — Not Performed
Target Score (0–4)	2 — Documented / Repeatable
Gap	**2**
Related Risk ID (CGI-RSK-001)	R-002, R-005
Risk if Unaddressed	Recovery that customers cannot see is commercially indistinguishable from continued outage; silence during an incident does more contract damage than the incident itself in an SMB SaaS base.
Priority	**P2**
Recommended Action	Produce a customer recovery communication pack with holding statements, a public status page, defined update intervals by severity, a named spokesperson and a written all-clear criterion owned by the Head of Customer Success.
Est. Effort	S (Small)
Owner (Job Title)	Head of Customer Success
ISO 27001:2022 Annex A Mapping	A.5.29 Information security during disruption; A.5.5 Contact with authorities; A.5.6 Contact with special interest groups

6. Function-level heatmap and radar chart

6.1 Heatmap data

Function	Categories	Avg Current	Target	Gap
GOVERN	6	1.33	2.67	1.33
IDENTIFY	3	1.67	2.67	1.00
PROTECT	5	1.00	3.00	2.00
DETECT	2	1.00	2.50	1.50
RESPOND	4	1.50	2.50	1.00
RECOVER	2	0.50	2.50	2.00
OVERALL	**22**	**1.23**	**2.68**	**1.45**

Paste-ready copies: **`03-heatmap-data.md`** and **`data/03-heatmap-data.csv`**. A pre-built chart is in **`images/03-radar-current-vs-target.png`**.

6.2 What the shape says

- **RECOVER is the worst Function at 0.50**, and it is the one that determines whether a bad day becomes an extinction event. Cypher Group Inc. holds backups it has never restored and has no way to tell roughly 200 customers that service is coming back.
- **PROTECT carries the largest absolute gap at 2.00**, driven entirely by the two Categories scoring zero. The company protects its people and its data reasonably well on paper, and its platform not at all.
- **GOVERN at 1.33 is higher than a pre-programme company would normally score**, which is the visible return on the CGI-POL policy pack — but it is held down by GV.SC at zero and GV.OV at one.
- **RESPOND at 1.50 is the highest-scoring operational Function**, because CGI-POL-005 is genuinely good. It cannot rise further until something exists to detect and something exists to analyse.

6.3 Building the radar chart (Google Sheets)

The current-versus-target radar is the single most recognisable image in GRC consulting and should be the thumbnail of this project. Build it in about five minutes:

1. Open Google Sheets → **File → Import** → upload `03-heatmap-data.csv` → *Insert new sheet*.
2. **Delete the OVERALL row before charting.** It is an average of averages and will distort the shape. Keep it on the sheet below the chart range if you want it visible.
3. Select the range covering `Function`, `Avg Current` and `Target` — three columns, six data rows, plus the header row. Leave the `Categories` and `Gap` columns out of the selection.
4. **Insert → Chart** → in the Chart editor open **Setup → Chart type** → scroll to **Other → Radar chart**.
5. Confirm **Use row 1 as headers** is ticked so the two series are named *Avg Current* and *Target*.
6. **Customise → Chart & axis titles** → title: `Cypher Group Inc. — NIST CSF 2.0 Maturity, Current vs Target`.
7. **Customise → Series** → set *Target* to a dashed line, *Avg Current* to a solid filled line. The target should read as an outline you are trying to reach, not as a second measurement.
8. **Customise → Vertical axis** → set **Min 0, Max 4**. Without this, Sheets auto-scales and the gap looks far worse than it is, which will be the first thing a competent interviewer catches.
9. Right-click the chart → **Download → PNG** at a width of at least 1200 px for the README and LinkedIn post.

For the conditional-format heatmap on the assessment grid: select the `Current Score` column in `03-nist-csf-gap-assessment.csv` once imported → **Format → Conditional formatting → Colour scale** → Minpoint `Number 0` red, Midpoint `Number 2` yellow, Maxpoint `Number 4` green. Pin the endpoints to numbers rather than to Min/Max so the colours mean the same thing in every future revision of this assessment.

---

7. Prioritised remediation roadmap

7.1 How the order was decided

Each recommendation carries a **risk reduction score (1–5)** — how much residual risk in CGI-RSK-001 it removes — divided by an **effort unit** (S = 1, M = 2, L = 3). The resulting **reduction per effort unit** is the primary sort key. Two deliberate overrides were applied and are stated in the Dependency column:

- **REC-05 (asset inventory)** is pulled forward above its ratio because REC-02, REC-11 and REC-15 cannot be completed properly without it. You cannot review access to, harden, monitor or restore an asset you have not recorded.
- **REC-16 (SAST and penetration testing)** is pushed back below its risk reduction because it is Large effort, needs budget approval, and needs the REC-06 pipeline controls to attach to.

7.2 The roadmap

Rec ID	Recommendation	Closes	CSF	Priority	Effort	RR	RR/Effort	Owner (Job Title)	Target Quarter	Dependency
REC-01	Complete MFA enrolment to 100% of accounts and retire the ACC-001 SMS exception ahead of its 03 Mar 2027 expiry, bringing practice into line with CGI-POL-002 §4.3.3 and §4.3.5.	R-001; TP-01 (partial)	PR.AA	P1	S	4	**4.00**	IT Operations Manager	Q4 2026	None
REC-02	Execute and evidence the first quarterly privileged access review mandated by CGI-POL-003 §4.7.1, producing a dated, signed review record with actioned removals.	R-003; PR.AA maturity 2 to 3	PR.AA	P1	S	4	**4.00**	IT Operations Manager	Q4 2026	Partial dependency on REC-05 for completeness
REC-03	Perform and document a full backup restore test to a clean environment, then publish CGI-POL-006 Backup and Recovery with RTO and RPO approved by Jerry Gold.	R-002; CG-01	RC.RP	P1	S	4	**4.00**	IT Operations Manager	Q4 2026	None
REC-04	Drive CGI-TRK-001 policy acknowledgement from 60% to 100% and add a completion gate to the CGI-POL-003 joiner process so no new starter gains access before acknowledging.	R-001, R-002; GV.PO maturity 2 to 3	GV.PO	P1	S	3	**3.00**	Head of People and Operations	Q4 2026	None
REC-05	Build an asset and SaaS inventory covering CloudCo accounts and data stores, CodeCo repositories, OfficeCo shared drives, ChatCo workspaces, PaymentsCo objects and staff endpoints, labelled per CGI-POL-004.	R-003, R-005; ID.AM maturity 1 to 2	ID.AM	P1	M	4	**2.00**	IT Operations Manager	Q1 2027	None

Rec ID	Recommendation	Closes	CSF	Priority	Effort	RR	RR/Effort	Owner (Job Title)	Target Quarter	Dependency
REC-06	Publish CGI-POL-007 Secure Development and Change Management and enforce CodeCo branch protection with mandatory peer review and no direct commits to main.	R-004; CG-02	PR.PS	P1	M	5	**2.50**	Chief Technology Officer	Q1 2027	None
REC-07	Enable AWS CloudTrail organisation-wide with log file validation, centralise logs with defined retention, and alert on root usage, IAM policy change, public S3 exposure and mass data download.	R-003, R-005; CG-03, CG-05 (partial)	DE.CM, DE.AE	P1	M	5	**2.50**	IT Operations Manager	Q1 2027	None
REC-08	Publish CGI-POL-008 Vulnerability Management and begin authenticated vulnerability scanning with severity-based remediation SLAs; feed results into the next CGI-RSK-001 revision.	R-002, R-004; CG-02	PR.PS, ID.RA	P1	M	4	**2.00**	Chief Technology Officer	Q1 2027	None
REC-09	Stand up an annual security awareness curriculum with an induction module and role-specific content for staff with production access, plus quarterly phishing simulations tracked in CGI-TRK-001.	R-001; CG-04	PR.AT	P1	M	4	**2.00**	Head of People and Operations	Q1 2027	REC-04 (acknowledgement gate)
REC-10	Establish a minuted quarterly security review with Jerry Gold reporting the seven CGI-RSK-001 KRIs, this maturity scorecard and TP-01 to TP-10 status.	GV.OV maturity 1 to 2	GV.OV	P2	S	2	**2.00**	Chief Executive Officer	Q1 2027	None

Rec ID	Recommendation	Closes	CSF	Priority	Effort	RR	RR/Effort	Owner (Job Title)	Target Quarter	Dependency
REC-11	Apply a CIS AWS Foundations Benchmark baseline and enable continuous cloud security posture monitoring across all CloudCo accounts.	R-005; CG-03	PR.IR	P1	M	5	**2.50**	IT Operations Manager	Q2 2027	REC-05 (asset inventory)
REC-12	Run a SEV1 tabletop exercise against CGI-POL-005 covering ransomware and cloud exposure, rehearsing the §5.6.3 GDPR 72-hour path, with a written lessons-learned record.	R-002, R-005; ID.IM maturity 1 to 2	RS.MA, RS.CO, ID.IM	P2	S	3	**3.00**	Chief Technology Officer	Q2 2027	REC-07 (something to detect with)
REC-13	Add a CEO-approved risk appetite statement and a defined annual plus event-driven re-assessment cadence to CGI-RSK-001 v1.1; re-confirm ACC-001 against the stated appetite.	GV.RM maturity 2 to 3	GV.RM, GV.OC	P2	S	2	**2.00**	Chief Executive Officer	Q2 2027	REC-10 (governance forum)
REC-14	Produce a customer incident and recovery communication pack: holding statements, public status page, update intervals by severity, named spokesperson and written all-clear criterion.	R-002, R-005; RC.CO maturity 0 to 2	RC.CO, RS.CO	P2	S	2	**2.00**	Head of Customer Success	Q2 2027	REC-12 (rehearsal)
REC-15	Build a tiered vendor inventory for CloudCo, CodeCo, ChatCo, OfficeCo and PaymentsCo with assurance artifacts and DPAs, and add permitted third-party destinations to CGI-POL-004 §4.2.	GV.SC maturity 0 to 2; R-005 (adjacent)	GV.SC	P1	M	3	**1.50**	Chief Technology Officer	Q2 2027	REC-05 (asset inventory)

Rec ID	Recommendation	Closes	CSF	Priority	Effort	RR	RR/Effort	Owner (Job Title)	Target Quarter	Dependency
REC-16	Introduce static application security testing in the CI pipeline and commission an annual third-party penetration test targeting the authorisation defect class behind R-004.	R-004; CG-02 (residual)	PR.PS	P2	L	5	**1.67**	Chief Technology Officer	Q3 2027	REC-06 (policy and branch protection first)
REC-17	Deploy data egress and data loss prevention monitoring on OfficeCo and CodeCo covering mass download, external sharing and repository cloning by departing staff.	R-003; CG-05	PR.DS, DE.CM	P3	M	3	**1.50**	Chief Technology Officer	Q3 2027	REC-07 (log centralisation)
REC-18	Document network segmentation, production access boundaries and the shared responsibility boundary between CloudCo and Cypher Group Inc.	R-004, R-005; PR.IR maturity	PR.IR	P3	M	3	**1.50**	IT Operations Manager	Q4 2027	REC-11 (baseline first)

7.3 Business rationale, recommendation by recommendation

- **REC-01 (P1, S (Small), Q4 2026).** Closes the roughly ten unprotected accounts behind the control-effectiveness discount CGI-RSK-001 applies to R-001. Highest risk reduction per unit of effort in the entire roadmap.
- **REC-02 (P1, S (Small), Q4 2026).** Converts the single most-cited unexecuted clause in the policy pack into operating evidence and is the cheapest available audit artifact.
- **REC-03 (P1, S (Small), Q4 2026).** CGI-RSK-001 refuses to credit backups for R-002 until a restore is proven (CG-01). One test converts an assumption into a capability.
- **REC-04 (P1, S (Small), Q4 2026).** Roughly twenty employees are currently bound by policies they have not read, which makes the entire Project 1 investment unenforceable.
- **REC-05 (P1, M (Medium), Q1 2027).** Sequenced early despite a mid-range ratio because it is a hard prerequisite for REC-02, REC-11 and REC-15. Dependency overrides ratio.
- **REC-06 (P1, M (Medium), Q1 2027).** R-004 is one of only two risks that stayed High after the Project 1 pack, precisely because no policy clause governs how code reaches production. This is the largest single maturity move available (PR.PS 0 to 2).
- **REC-07 (P1, M (Medium), Q1 2027).** Moves the company from zero detection capability to a defensible one and simultaneously unblocks RS.AN incident analysis, which is currently impossible for want of retained logs.
- **REC-08 (P1, M (Medium), Q1 2027).** Satisfies CSF ID.RA-01 by technical discovery rather than workshop judgement, which is the stated reason ID.RA is capped at 3 rather than 4.
- **REC-09 (P1, M (Medium), Q1 2027).** R-001 carries the joint-highest inherent score in the register (20) and its principal control is human judgement that has been trained once, at induction, and never tested.
- **REC-10 (P2, S (Small), Q1 2027).** Creates the governance loop that releases budget and keeps remediation alive once the assessment ends; the minutes are themselves the oversight evidence.

- **REC-11 (P1, M (Medium), Q2 2027).** R-005 is the second of the two risks that stayed High. A baseline plus posture monitoring is the only control that addresses misconfiguration as a class rather than one bucket at a time.
- **REC-12 (P2, S (Small), Q2 2027).** Converts three policy-only Categories into exercised ones in a single half-day and produces the lessons-learned artifact that ID.IM currently lacks entirely.
- **REC-13 (P2, S (Small), Q2 2027).** ACC-001 was accepted against an undeclared tolerance. Declaring appetite is what makes every future acceptance defensible rather than personal.
- **REC-14 (P2, S (Small), Q2 2027).** Silence during an incident does more contract damage across roughly 200 SMB customers than the incident itself.
- **REC-15 (P1, M (Medium), Q2 2027).** The only Category scored zero that is also a hard commercial blocker: enterprise buyers treat a missing vendor register as an immediate fail. Delivered 15 Sep 2026 as Project 4 (CGI-TPR-001), three quarters ahead of its Q2 2027 slot.
- **REC-16 (P2, L (Large), Q3 2027).** Peer review alone will not find an authorisation flaw reliably. This is what finally moves R-004 off residual High, but it needs budget and a pipeline to attach to, so it follows rather than leads.
- **REC-17 (P3, M (Medium), Q3 2027).** R-003 is prevented on paper by the CGI-POL-003 four-hour revocation but remains entirely undetectable in the window before a leaver is processed.
- **REC-18 (P3, M (Medium), Q4 2027).** Required for ISO 27001 A.8.22 and expected in any cloud audit; low urgency only because the baseline in REC-11 delivers most of the practical protection first.

7.4 Wave plan

Wave	Window	Recommendations	What it buys
Wave 1 — Evidence	Q4 2026 (0–90 days)	REC-01 to REC-04	Four Small-effort actions that convert existing written controls into evidenced ones. No budget required.
Wave 2 — Capability	Q1 2027	REC-05 to REC-10	The first real controls the company has never had: inventory, code review, logging, scanning, training, oversight.
Wave 3 — Hardening and rehearsal	Q2 2027	REC-11 to REC-15	Cloud baseline, incident rehearsal, risk appetite, customer communications, vendor programme.
Wave 4 — Assurance	Q3–Q4 2027	REC-16 to REC-18	Application security testing, egress monitoring and architecture documentation. Budget-dependent.

Projected maturity on completion of Waves 1 and 2 (REC-01 to REC-10): 1.73 / 4.00, up from 1.23 — a 41% improvement achieved almost entirely with existing staff time. Completion of all four waves reaches the declared target of 2.68.

---

8. Executive summary (one page)

> **To:** Jerry Gold, Chief Executive Officer · **From:** O.S, Assessor · **Date:** 15 September 2026 **Subject:** NIST CSF 2.0 security maturity — where we stand and what to do first

Overall maturity: 1.23 out of 4.00

Measured against all 22 Categories of the NIST Cybersecurity Framework 2.0, on a 0–4 scale where 2 means *written down* and 3 means *demonstrably happening*. Our declared target is **2.68**. The gap is **1.45**.

The three findings that matter

1. Our policies are good and largely unenforced. The CGI-POL-001 to CGI-POL-005 pack is genuinely strong — it is why we are at 1.23 rather than near zero. But CGI-TRK-001 shows **60% policy acknowledgement**, **80% MFA enrolment**, and **zero completed privileged access reviews** against a quarterly mandate in CGI-POL-003 §4.7.1. We are carrying the cost of a security programme without yet collecting the benefit.

2. We have no control at all over how code reaches production, or how our cloud is configured. PR.PS Platform Security and PR.IR Technology Infrastructure Resilience both score **0 out of 4**. There is no mandatory code review, no branch protection, no vulnerability scanning, no CloudCo configuration baseline and no posture monitoring. This is the documented reason the two risks that stayed **High** after our policy work — **R-004** (production API authorisation flaw) and **R-005** (CloudCo misconfiguration exposing customer data) — did not come down. They are not High because we failed at policy; they are High because policy was never the control that addressed them.

3. We hold backups we have never restored. RECOVER is our weakest Function at **0.50 out of 4**. No restore test has been performed, no recovery time or recovery point objective has been declared, and we have no way to tell approximately 200 customers that service is returning. An untested backup is an assumption, not a capability.

Business impact

> **In its present state Cypher Group Inc. cannot credibly complete a standard enterprise security questionnaire.** The sections that stop us — vendor management, secure development, vulnerability management, logging and monitoring, and tested disaster recovery — are precisely the Categories scoring 0 or 1 in this assessment. Every one of the roughly 200 SMB customers that grows into an enterprise buyer, and every enterprise prospect we approach, will ask for exactly this evidence. **The gap is therefore a revenue gate, not only a risk position**: it constrains which deals we can pursue against an ARR base of approximately USD 3.6M, and it is the reason ISO 27001 certification is currently out of reach.

What I am asking for

	Ask	Cost
Now (0–90 days)	Approve REC-01 to REC-04 — finish MFA rollout, run the first access review, test a backup restore, get policy acknowledgement to 100%	Staff time only. No spend.
Q1 2027	Approve REC-05 to REC-10 — asset inventory, CodeCo branch protection and CGI-POL-007, centralised logging and alerting, vulnerability scanning and CGI-POL-008, security awareness training, quarterly security review	Within the USD 32,100 year-one estimate already costed in CGI-RSK-001
Standing	A minuted quarterly security review at which I report the seven KRIs and this scorecard	90 minutes per quarter of your time

If Waves 1 and 2 complete, overall maturity moves from 1.23 to approximately 1.73 out of 4.00 — most of it bought with existing staff time — and PR.PS moves off zero, which is the single change that begins to bring R-004 and R-005 down from High.

---

9. Internal consistency checks and limitations

9.1 Reconciliation against CGI-RSK-001 residual risk positions

A maturity scorecard that disagrees with the organisation's own risk register is worse than no scorecard at all. The governing rule applied here:

> **No Category may be scored 3 or above while a residual High risk sits behind it, unless the reason is stated in writing.**

CGI-RSK-001 leaves two risks at residual High after treatment: **R-004** (residual 12) and **R-005** (residual 12). One Category in this assessment scores 3 and is linked to both. It is explained here:

Category	Score	Linked to residual High?	Explanation
ID.RA Risk Assessment	3	Yes — R-004 and R-005	**Not a contradiction.** ID.RA measures whether risk is *identified and analysed*, not whether it is *treated*. R-004 and R-005 being visible, scored and documented at all **is the risk-identification process working correctly**. The residual High sits in the Categories that own the missing controls — **PR.PS** (secure development, control gap CG-02) and **PR.IR** (cloud configuration, control gap CG-03) — and both of those score **0**. Finding a High risk is evidence of a healthy ID.RA, not evidence of a broken one.

The inverse check — the one that would be a real contradiction — also passes. No Category that owns the control driving a residual High risk scores above 0:

Residual High risk	Driving control gap	Owning Category	Score	Consistent?
R-004 — production API authorisation flaw (residual 12)	CG-02 — no secure development, code review, change management or vulnerability management	PR.PS Platform Security	**0**	✓ A High risk behind a Category scoring 0 is exactly what the register predicts
R-005 — CloudCo misconfiguration exposing customer data (residual 12)	CG-03 — no cloud configuration baseline and no drift detection	PR.IR Technology Infrastructure Resilience	**0**	✓ Same

Control gap coverage. All five CGI-RSK-001 control gaps are accounted for in this assessment:

Control gap	Description carried forward from CGI-RSK-001	Primary Category	Score	Closing recommendation
CG-01	No backup, recovery, RPO/RTO or restore-testing obligation	RC.RP / PR.IR	1 / 0	REC-03
CG-02	No secure development, code review, change management or vulnerability management policy	PR.PS	0	REC-06, REC-08, REC-16
CG-03	No cloud configuration baseline and no automated configuration monitoring or drift detection	PR.IR / DE.CM	0 / 1	REC-07, REC-11
CG-04	Security awareness training at induction only; no recurring programme or simulation	PR.AT	1	REC-09
CG-05	No data loss prevention tooling; monitoring is metadata-level only	PR.DS / DE.CM	2 / 1	REC-07, REC-17

9.2 Where this assessment is deliberately generous, and where it is harsh

- **Generous: ID.RA at 3.** A stricter assessor would cap it at 2 on the grounds that CSF Subcategory ID.RA-01 requires vulnerabilities in assets to be identified, and Cypher Group Inc. performs no scanning at all. The 3 is awarded because the register itself was performed, evidenced and approved to a published method, and the scanning deficiency is recorded openly in the finding and capped the score at 3 rather than 4.
- **Generous: RC.RP at 1 rather than 0.** CloudCo native snapshots do exist. A backup that has never been restored is not a recovery capability, but it is more than nothing.
- **Harsh: PR.PS and PR.IR at 0.** Engineers at Cypher Group Inc. undoubtedly review one another's code informally and configure CloudCo with some care. None of it is written, mandated, enforced or evidenced, and under the §3.1 scale an unwritten, unevidenced practice cannot exceed 1 — and an entirely unrecorded one is 0.
- **Harsh: GV.SC at 0.** Cypher Group Inc. uses five reputable providers who are themselves well-certified, and CGI-POL-001 §4.6.1 already requires CTO approval for new services. The score reflects Cypher Group Inc.'s own assurance activity, which is nil — one approval rule with no inventory or method behind it is a fragment, not a programme. **Your vendor's certification is your vendor's control, not yours.**

9.3 Verification performed

Check	Result
22 Categories assessed, no duplicates, all 6 Functions covered	✓ 6 + 3 + 5 + 2 + 4 + 2 = 22
Every Current and Target score within 0–4; no Target below Current	✓
Gap = Target − Current for every row	✓ computed, not typed
Function averages and overall average recomputed programmatically	✓ current sum 27 ÷ 22 = 1.2273 (1.23); target sum 59 ÷ 22 = 2.6818 (2.68)
Target distribution reconciles to the target sum	✓ (15 × 3) + (7 × 2) = 59
No Category scored ≥ 3 behind a residual High risk without a written explanation	✓ one instance, explained in §9.1
Every Category cites at least one CGI-POL clause or a named absence of one	✓
Every clause-level fragment that touches a zero-scored Category is named and weighed (§3.1 fragment rule)	✓
Control gap IDs match CGI-RSK-001 §4.3 exactly	✓ CG-01 to CG-05
Every Category carries an ISO 27001:2022 Annex A mapping	✓
Every Owner is a job title, never a named individual	✓
Recommendations ≥ 12	✓ 18
Every recommendation has priority, effort, owner, target quarter, dependency and a Risk ID or control gap	✓
Case-study notice present	✓

10. Glossary

Term	Definition
Annex A (ISO/IEC 27001:2022)	The list of 93 information security controls in four themes (organisational, people, physical, technological) against which an ISMS is assessed.
CG-01 to CG-05	Control gaps carried forward from CGI-RSK-001: CG-01 backup and recovery · CG-02 secure development and vulnerability management · CG-03 cloud configuration baseline and drift detection · CG-04 recurring awareness training · CG-05 data loss prevention.
Fragment rule	A single clause touching one outcome is recorded but does not lift a Category a level on its own (§3.1).
CMMI	Capability Maturity Model Integration. Developed at Carnegie Mellon University's Software Engineering Institute; origin of the 0–4 scale used in §3.1.
Category	An outcome group inside a CSF Function. 22 in CSF 2.0. The assessment depth used here.
CSF	Cybersecurity Framework. CSF 2.0 is NIST publication CSWP 29, published 26 February 2024.
Design effectiveness	The control is properly written and would work if followed. Worth maturity 2.
Evidence source	The retained artifact that proves a control operated — a signed record, a test result, a ticket, an export. Without one, no score above 2.
Function	One of the six top-level CSF groupings: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER.
Gap assessment	A structured comparison of current state against a declared target state, producing prioritised, owned remediation actions.
GDPR	EU General Data Protection Regulation. Article 33 requires notification of a personal data breach to the supervisory authority within 72 hours of awareness.
Inherent risk	Risk before existing controls are considered. Aggregate 92, mean 18.4 in CGI-RSK-001.
JML	Joiner–Mover–Leaver. The access lifecycle governed by CGI-POL-003.
KRI	Key Risk Indicator. A measurable early-warning signal with a defined threshold and owner. CGI-RSK-001 defines seven.
Maturity	How consistently, repeatably and verifiably an outcome is achieved — not whether it exists.

Term	Definition
MFA	Multi-Factor Authentication. Reduces the likelihood of credential compromise; it does not reduce impact.
NIST	National Institute of Standards and Technology, an agency of the US Department of Commerce. Publishes standards; is not a regulator.
Operating effectiveness	The control demonstrably ran, on schedule, and produced retained evidence. Required for maturity 3.
P1 / P2 / P3	Priority bands. P1 within 90 days; P2 within 6 months; P3 within 12 months.
Profile	CSF term. A Current Profile describes what an organisation does today; a Target Profile describes what it intends to do. The distance between them is the gap.
Residual risk	Risk remaining after existing controls. Aggregate 44, mean 8.8 in CGI-RSK-001 — a 52% reduction attributable to the CGI-POL pack.
Risk appetite	The amount of residual risk leadership has formally agreed to carry. Cypher Group Inc. has not yet declared one (finding GAP-002).
RTO / RPO	Recovery Time Objective — how quickly service must be restored. Recovery Point Objective — how much data loss is tolerable. Neither is declared at Cypher Group Inc. (finding GAP-021).
S / M / L	Effort bands. S ≤ 2 weeks of an owner's part-time attention; M ≤ 2 months; L > 2 months or requires budget approval or hiring.
SEV1 to SEV4	Incident severity bands defined in CGI-POL-005.
Subcategory	The smallest CSF unit — a single specific outcome. 106 in CSF 2.0. Not assessed in this revision.
Tier (1–4)	CSF Implementation Tier: Partial, Risk Informed, Repeatable, Adaptive. Describes the rigour of risk governance. Explicitly not a maturity model.
TP-01 to TP-10	Treatment actions from CGI-RSK-001, each with an owner and estimated cost totalling USD 32,100 in year one.

Source documents

ID	Document	Version	Status
CGI-POL-001	Acceptable Use Policy	1.0	Approved
CGI-POL-002	Password and MFA Policy	1.0	Approved
CGI-POL-003	Onboarding / Offboarding Access Control Policy	1.0	Approved
CGI-POL-004	Data Classification Policy	1.0	Approved
CGI-POL-005	Incident Reporting Policy	1.0	Approved
CGI-TRK-001	Sign-off and Training Tracker	current	60% acknowledged, 80% MFA enrolled
EXC-001 to EXC-003	Exception Register	current	Open
CGI-RSK-001	Master Information Security Risk Register	1.0	Approved
NIST CSWP 29	The NIST Cybersecurity Framework (CSF) 2.0	2.0	Published 26 Feb 2024
ISO/IEC 27001:2022	Information security management systems — Requirements	2022	Referenced for Annex A mapping

End of CGI-GAP-001 v1.0. Prepared by O.S. Approved by Jerry Gold.